ICare | ZAP Retest

Fresh scanner results and remediation verification

Friday, 16 October 2026 at 16:31:41 GMT+5:30

What was verified

20 of 20 security findings passed targeted regression checks; 0 failed. The original Modern Web Application entry is informational and requires no fix. These checks were performed through a real ZAP proxy against the updated application and a dedicated synthetic database.

Verification	Result
Scanner	ZAP 2.17.0
Target	http://127.0.0.1:60354
Targeted security regressions	20 passed / 0 failed / 1 informational
Fresh passive alerts	4 alert types; 37 instances
Native severity totals (instances)	High: 0 | Medium: 6 | Low: 28 | Informational: 3
Manual review of Low alerts	28 timestamp matches are color/MD5 constants (false positives)
Test data cleanup	Isolated synthetic test database dropped after retest

How to read this report

PASS means the specific original finding was blocked in the targeted test. It does not mean the scanner found zero alerts or that every possible vulnerability was tested. Fresh passive findings are listed separately, with severity and evidence. Manual regression checks are not represented as automatically discovered ZAP findings.

Original assessment

The supplied original report listed 21 alert types: 11 High, 5 Medium, 4 Low and 1 Informational. It combined 13 manually verified findings with automatic passive alerts. This retest records all 21 entries below. Scan counts are not directly comparable because they include different traffic and fixture values.

Original findings | retest

Each row maps to the original report. Evidence includes observed HTTP outcomes and persisted fixture state. The full machine-readable evidence is in remediation-results.json.

ID / original finding	Status	Fix and verification evidence
Z01 PII disclosure through removed card API	PASS	GET 404; POST 404; no card data returned Code: server.js API routing
Z02 Client-controlled order price and total	PASS	Submitted 0.01; server itemsPrice=100; totalPrice=125 Code: routes/orderRoutes.js; orderPricing.js
Z03 Cross-user order disclosure	PASS	Unrelated customer 404; owner 200 Code: routes/orderRoutes.js
Z04 Cross-user payment modification	PASS	Unrelated customer 403; isPaid remains false Code: routes/orderRoutes.js
Z05 Full card number and CVV persisted/returned	PASS	Removed API rejects reads/writes; isolated database cards collection has zero records. Existing installation was checked separately. Code: Removed card routes/models; purgeLegacyCards.js
Z06 Payment marked paid without provider verification	PASS	Even administrator receives 400 for PayPal; isPaid remains false. Online payment disabled. Code: routes/orderRoutes.js
Z07 Customer changes another order delivery	PASS	Customer 403; isDelivered remains false Code: routes/orderRoutes.js
Z08 Password reset token reuse	PASS	First reset 200; reuse 400; old access token 401 Code: routes/userRoutes.js; utils.js
Z09 Password-reset JWT accepted as access token	PASS	Legacy reset-shaped JWT on protected order API: 401 Code: utils.js
Z10 Prescription disclosure to unrelated customer	PASS	Customer 403; administrator 200 Code: routes/prescriptionRoutes.js
Z11 Prescription modification by unrelated customer	PASS	Customer 403; prescription unchanged Code: routes/prescriptionRoutes.js
Z12 Missing Content Security Policy	PASS	CSP present on home/sign-in/sign-up. Inline styles intentionally permitted for current UI; scanner warnings are reported separately. Code: security.js
Z13 Missing anti-clickjacking header	PASS	X-Frame-Options DENY and CSP frame-ancestors none on all three HTML routes Code: security.js
Z14 Missing Subresource Integrity	PASS	Pinned Font Awesome CSS has verified SHA-384 integrity and crossorigin=anonymous Code: frontend/public/index.html

ID / original finding	Status	Fix and verification evidence
Z15 Cross-user support ticket response injection	PASS	Owner 201; unrelated customer 404; only owner response persisted Code: routes/ticketRoutes.js
Z16 Single-character registration password	PASS	Registration 400; no user created Code: routes/userRoutes.js
Z17 Application error disclosure	PASS	Authenticated malformed order ID: 400; generic Invalid request response Code: security.js
Z18 X-Powered-By framework disclosure	PASS	X-Powered-By absent on home/sign-in/sign-up Code: server.js
Z19 Missing X-Content-Type-Options	PASS	nosniff present on home/sign-in/sign-up Code: security.js
Z20 Internal database details in order errors	PASS	Authenticated malformed ID returns HTTP 400 with no internal database detail Code: security.js
Z21 Modern Web Application	INFO	React SPA identification; no remediation required Code: Original report informational alert

Fresh ZAP passive alerts

These are actual scanner findings from this run. A successful original-finding regression can coexist with a new hardening warning. No alert has been suppressed to make this report appear clean.

Alert	Risk / count	Scanner description and evidence
CSP: Wildcard Directive	Medium 3 instances	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides Example: http://127.0.0.1:60354/ Evidence: default-src 'self'; base-uri 'self'; object-src 'none'; frame-ancestors 'none'; form-action 'self'; Remaining work: img-src permits all HTTPS hosts. Restrict it to the approved product-image, upload, and map image origins.
CSP: style-src unsafe-inline	Medium 3 instances	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides Example: http://127.0.0.1:60354/signin Evidence: default-src 'self'; base-uri 'self'; object-src 'none'; frame-ancestors 'none'; form-action 'self'; Remaining work: replace inline styles/style blocks with CSP-compatible styles/nonces while testing Bootstrap, charts, maps and notifications.
Modern Web Application	Informational 3 instances	The application appears to be a modern web application. If you need to explore it automatically then the Client Spider may well be more effective than the standard one. Example: http://127.0.0.1:60354/ Evidence: (header or response-based finding)
Timestamp Disclosure - Unix	Low 28 instances	A timestamp was disclosed by the application/web server. - Unix Example: http://127.0.0.1:60354/static/js/main.8543b343.js Evidence: 1732584194 Manual review: 28 matches are static library color/MD5 constants, not leaked timestamps. False positives; native alerts retained unchanged.

Scope and reproducibility

Method

Isolated synthetic database; authenticated manual regression requests through actual ZAP proxy plus passive scanning of visited HTML, assets, and API responses. No unrestricted active scan, external service testing, Google login, or password-reset email delivery. Reset fixture seeded directly. No real customer data used.

Coverage

Home, sign-in, sign-up, manifest, robots, production JavaScript/CSS assets, card endpoint removal, server-side pricing, order ownership, payment and delivery authorization, reset replay, session revocation, reset/access JWT separation, prescription authorization, ticket ownership, weak registration passwords, malformed identifiers, and response headers. Positive owner/admin controls were included.

Limits and remaining work

This is a targeted authenticated regression assessment plus passive scan, not an unrestricted active scan. Google consent, Cloudinary, email delivery, external payment services and deployment TLS were not exercised. Production headers were tested using NODE_ENV=production on local HTTP; this does not verify real HTTPS configuration. External CDN resources were not actively scanned. Business rules not listed above and dependency vulnerabilities require separate assessment.

The CSP deliberately allows inline styles needed by the current React/Bootstrap UI and selected Google resources. A scanner may flag this as a hardening opportunity even though the original missing-CSP finding is resolved. Review every fresh passive alert before claiming a zero-alert scan.

The configured existing application database was separately checked read-only on 16 October 2026: zero legacy cards documents and zero orders with cardDetails. The isolated retest database does not establish the state of other deployments or backups. The browser cleanup runs when the upgraded app is opened.

Artifacts

optical-store-zap-retest.html: native ZAP HTML output.
zap-alerts.json: actual passive alerts and scanner summary.
remediation-results.json: all 21 mappings and observed outcomes.
scripts/zap-retest.mjs: repeatable test harness; disposable database only.
scripts/generate-zap-retest-report.mjs: this PDF generator.

Scanner reference: https://www.zaproxy.org/docs/desktop/start/
Download source: https://www.zaproxy.org/download/